

บทที่ 2

ทฤษฎีและหลักการเบื้องต้น

2.1 ระบบตรวจจับผู้บุกรุกคอมพิวเตอร์

2.1.1 ความหมายของระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์

ระบบตรวจจับผู้บุกรุกคอมพิวเตอร์ คือ กระบวนการในการตรวจสอบเหตุการณ์ที่เกิดขึ้นในระบบคอมพิวเตอร์หรือระบบเน็ตเวิร์ค โดยรวบรวมข้อมูลจากหลายแหล่ง นำไปทำการวิเคราะห์เพื่อหาเหตุการณ์ที่ผิดปกติ จากนั้นตอบสนองต่อเหตุการณ์นั้นตามผลที่ได้วิเคราะห์มา

กล่าวโดยสรุปแล้วระบบตรวจจับผู้บุกรุกคอมพิวเตอร์ คือ ระบบที่ทำหน้าที่ติดตามดูการทำงานที่เกิดขึ้นบนระบบคอมพิวเตอร์ เพื่อค้นหาร่องรอยที่บ่งบอกว่ามีผู้พยายามบุกรุกระบบคอมพิวเตอร์ หรือค้นหาการกระทำที่เกินขอบเขตสิทธิ์ของผู้ใช้ระบบ

การบุกรุก คือ ทุกสถานะหรือเหตุการณ์ที่หลบซ่อนเข้ามาเพื่อทำความเสียหายแก่ระบบ ได้แก่ การเปิดเผยข้อมูล การทำลายข้อมูล การแก้ไขข้อมูล การปฏิเสธการเข้าถึงข้อมูล หรือกระบวนการของระบบ เข้าสู่ระบบที่ไม่อนุญาตให้ใช้

2.1.2 ความจำเป็นที่ต้องมีระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์

เมื่อคำนึงถึงเรื่องความปลอดภัยของคอมพิวเตอร์มักเป็นการยากในการมองภาพที่ชัดเจนว่า อะไรที่จะบ่งบอกได้ว่าการใช้งานคอมพิวเตอร์มีความปลอดภัย เนื่องจากความปลอดภัยของคอมพิวเตอร์เป็นสิ่งที่จับต้องไม่ได้และยากต่อการวัด แต่อย่างไรก็ตามเราสามารถเปรียบเทียบความปลอดภัยของคอมพิวเตอร์กับการรักษาความปลอดภัยสถานที่ ในการรักษาความปลอดภัย (รปภ.) สถานที่นั้นนอกจากการ จัดบริเวณที่ต้อง รปภ. ให้มีรั้วรอบขอบชิด มีกุญแจที่ใช้ล็อกประตูหรือทางเข้าออก สิ่งหนึ่งที่จะขาดไม่ได้คือการจัดให้มีบุคคลหรืออุปกรณ์ที่คอยตรวจสอบ การละเมิดต่ออุปกรณ์หรือเครื่องกีดขวางที่ติดตั้งเพื่อความปลอดภัย ทั้งนี้เนื่องจากอาจมีผู้ไม่หวังดีพยายามบุกรุกโดยทำลายอุปกรณ์หรือเครื่องกีดขวางดังกล่าว ดังนั้นเราจึงต้องอาศัยระบบที่ใช้ตรวจสอบเมื่อมีการทำลายหรือล่วงล้ำต่ออุปกรณ์หรือเครื่องกีดขวางที่ได้ติดตั้งไว้อีกชั้นหนึ่ง ตัวอย่างอุปกรณ์ที่ใช้ตรวจสอบเช่น ระบบสัญญาณเตือนขโมยที่ใช้ควบคู่กับรั้วที่แข็งแรง

เป็นที่รู้กันดีว่าระบบคอมพิวเตอร์และเครือข่ายมีการออกแบบที่ไม่ค่อยปลอดภัยมากนักทำให้ผู้บุกรุกมีโอกาสที่จะบุกรุกระบบได้ง่ายแม้ว่ามีไฟร์วอลล์ (Firewall) อยู่แล้วก็ตามแต่ก็ไม่สามารถป้องกันการบุกรุก 100 เปอร์เซ็นต์ เนื่องจากไฟร์วอลล์เป็นการป้องกันระหว่างระบบคอมพิวเตอร์ภายในเครือข่าย (Internal networks) กับระบบภายนอก (Internet) หากผู้บุกรุกเป็นคนภายในไฟร์วอลล์เอง ก็ไม่สามารถป้องกันได้ ดังนั้นการมีไฟร์วอลล์ เปรียบเสมือนการมีรั้วกั้นรอบบ้าน และระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์เปรียบเสมือนการติดตั้งกล้องวิดีโอคอยตรวจสอบสิ่งผิดปกติทำให้การป้องกันระบบทำได้ยิ่งขึ้น

2.1.3 หน้าที่ของระบบตรวจจับผู้บุกรุก

- 1) ตรวจสอบและวิเคราะห์กิจกรรมของผู้ใช้และระบบ
- 2) ตรวจสอบรูปแบบของระบบ และ ความอ่อนแอของระบบ
- 3) กำหนดความมั่นคงของระบบที่สำคัญและไฟล์ข้อมูล
- 4) จัดทำกิจกรรมต่างที่เข้ามาโจมตี
- 5) วิเคราะห์ที่เป็นมาตรฐานสำหรับรูปแบบพฤติกรรมที่ผิดปกติ
- 6) ตรวจสอบการทำงานของระบบด้วยการจำกิจกรรมของผู้ใช้ที่สะท้อนถึงนโยบายการบุกรุก

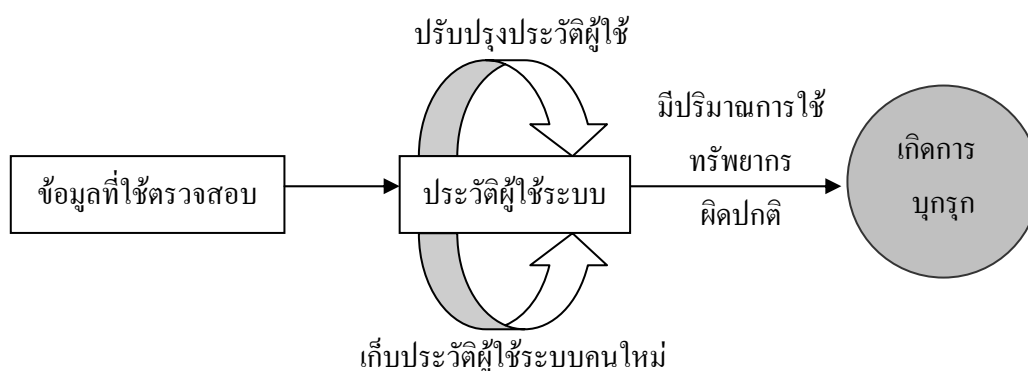
2.1.4 ชนิดของระบบตรวจจับผู้บุกรุก

- 1) ระบบตรวจจับผู้บุกรุกในโฮสต์ (Host-base IDS) ถูกออกแบบมาสำหรับการตรวจสอบโฮสต์ เพียงโฮสต์เดียว จะใช้ข้อมูลการใช้งานระบบเป็นอินพุต สำหรับระบบตรวจจับผู้บุกรุก
- 2) ระบบตรวจจับผู้บุกรุกในโฮสต์แบบกระจาย (Distributed Host-Based IDS) คือการใช้ระบบตรวจจับผู้บุกรุกรวมกันจากหลายๆ โฮสต์ จะใช้ข้อมูลการใช้งานระบบจากโฮสต์ หรือข้อมูลจากหลายๆ โฮสต์ ซึ่งข้อมูลจะดำเนินการบนเครื่องศูนย์กลาง
- 3) ระบบตรวจจับผู้บุกรุกทางเครือข่าย (Network-based IDS) วิเคราะห์การส่งจ่ายข้อมูลบนแลน เพื่อที่จะทำการตรวจจับพฤติกรรม

2.1.5 ประเภทการตรวจจับ แบ่งได้เป็น 3 แบบ คือ

2.1.5.1 วิธีตรวจสอบการใช้งานระบบที่ผิดปกติ (Anomaly Intrusion Detection Model)

วิธีตรวจสอบการใช้งานทรัพยากรระบบที่ผิดปกติตั้งอยู่บนสมมติฐานที่ว่ากระทำการใดๆ ที่เป็นการบุกรุกจะต้องมีการใช้งานระบบอย่างผิดปกติ โดยจะตรวจจับผู้บุกรุกโดยการตรวจสอบจากประวัติการทำงานที่เคยทำมาแล้วเปรียบเทียบกับการทำงานปัจจุบัน ถ้าการทำงานแตกต่างกันมาก หรือเกิดการใช้งานระบบอย่างผิดปกติ แสดงว่าเกิดการบุกรุก หมายความว่าในการตรวจจับวิธีนี้ต้องมีการเก็บพฤติกรรมปกติของผู้ใช้ระบบไว้เพื่อเปรียบเทียบกับพฤติกรรมใดที่ผิดปกติ ดังแสดงในรูป



รูปที่ 2-1 การทำงานของการตรวจจับผู้บุกรุกโดยวิธีตรวจสอบการใช้งานระบบที่ผิดปกติ

จากรูป 2-1 ข้อมูลที่ใช้ตรวจสอบ (Audit data) ซึ่งเก็บบันทึกโดยระบบ จะถูกนำมาปรับปรุงไฟล์ประวัติ (Profile) ของผู้ใช้ พร้อมกันนั้นนำข้อมูลนี้มาเปรียบเทียบกับสถิติการใช้งานของผู้ใช้แต่ละคน หากพบว่ามีความผิดปกติที่ระบุไว้ในสถานะที่มีการบุกรุกเกิดขึ้น และถ้ามีการตรวจสอบโดยใช้ข้อมูลใหม่ๆ ก็สามารถเพิ่มในไฟล์ประวัติได้ ทำให้ระบบสามารถตรวจจับการบุกรุกใหม่ๆ ได้

ข้อดีของการตรวจจับโดยวิธีตรวจสอบการใช้งานระบบที่ผิดปกติ คือ

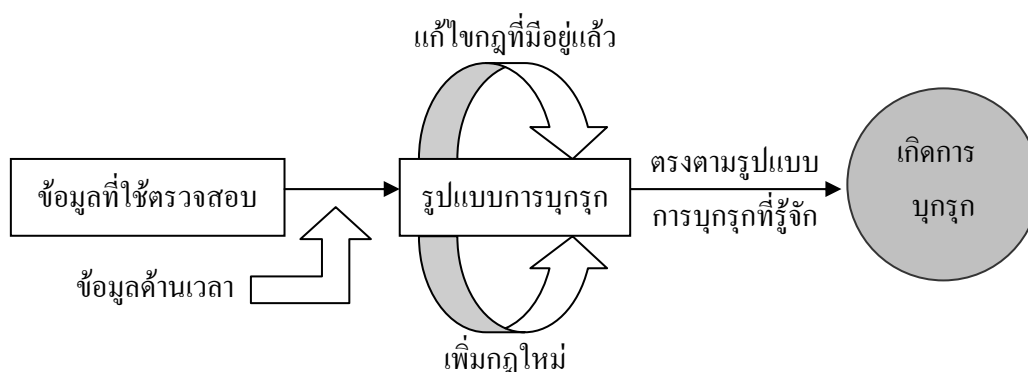
- สามารถตรวจจับบุกรุกแบบที่ไม่เคยเจอมาก่อนได้ โดยที่ไม่ต้องรู้รายละเอียดของการบุกรุกนั้นๆ
- สามารถสร้างข้อมูลเพื่อที่จะระบุพฤติกรรมส่งต่อการเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จักได้ (Misuse)

ข้อเสียของการตรวจจับโดยวิธีตรวจสอบการใช้งานระบบที่ผิดปกติ คือ

- อาจมีพฤติกรรมการใช้งานทรัพยากรระบบของผู้ใช้ที่ผิดปกติเกิดขึ้นแต่ไม่ได้เป็นการบุกรุกระบบ ทำให้ระบบสถานะผิดพลาด
- ตรวจไม่พบการบุกรุกระบบเนื่องจากการบุกรุกนั้นไม่ได้ใช้ทรัพยากรระบบอย่างผิดปกติ
- หากผู้บุกรุกค่อยๆ เปลี่ยนพฤติกรรมการใช้งานไปที่ละเล็กละน้อยระบบจะไม่สามารถตรวจจับความผิดปกติได้

2.1.5.2 วิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จัก (Misuse Intrusion Detection Model)

วิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จักประกอบด้วย การเก็บบันทึกและการระบุรูปแบบของการบุกรุกซึ่งอาจบุกรุกจากจุดอ่อนของระบบหรือการละเมิดกฎรักษาความปลอดภัย โดยมีตัวตรวจจับคอยดูแลกิจกรรมต่างๆ ที่กระทำในปัจจุบันว่าเหมือนกับพฤติกรรมบุกรุกที่เคยเกิดขึ้นหรือได้รับรายงานว่าเป็นการบุกรุกหรือไม่ ซึ่งหัวใจสำคัญของการตรวจจับวิธีนี้คือต้องระบุถึงสัญญาณการเกิดการบุกรุกทั้งหมดที่เป็นไปได้ ในบางระบบมีการใช้กฎ (Rule-based expert system) โดยตั้งกฎขึ้นจากพฤติกรรมที่น่าสงสัย เช่น การ login ล้มเหลวเกินกว่า 3 ครั้งต่อเนื่องกัน ในเวลา 5 นาที ถือว่าพยายามบุกรุก



รูปที่ 2-2 การทำงานของวิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จัก

จากรูป 2-2 ข้อมูลที่ใช้ตรวจสอบจะถูกนำมาเปรียบเทียบกับกฎ (Rules) ที่มีอยู่สังเกตว่ามีการนำข้อมูลทางเวลาเข้ามาพิจารณาด้วย การตรวจจับการบุกรุกโดยวิธีนี้สามารถมีการแก้ไขกฎหรือเพิ่มกฎได้ในระบบที่เป็นปัญญาประดิษฐ์ (Artificial Intelligence) ระบบอาจทำการแก้ไขกฎหรือเพิ่มกฎได้ด้วยตัวเอง

ข้อดีของวิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จัก คือ

- การตรวจจับมีประสิทธิภาพที่น่าเชื่อถือ มีความผิดพลาดน้อย
- การตรวจจับทำได้อย่างรวดเร็ว ทำให้สามารถป้องกันระบบได้อย่างทันทั่วถึง

ข้อเสียของวิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จัก คือ

- ประสิทธิภาพของระบบการตรวจจับชนิดนี้ขึ้นอยู่กับรูปแบบการบุกรุกที่ระบบรู้จัก
- มีข้อจำกัดในเรื่องจำนวนของรูปแบบในการบุกรุก ซึ่งหากเป็นการบุกรุกที่ระบบไม่รู้จักมาก่อน จะทำให้ไม่สามารถตรวจจับการบุกรุกได้

2.1.5.3 วิธีการแบบผสม (Hybrid detection model)

เป็นการนำ วิธีตรวจสอบการใช้งานระบบที่ผิดปกติ และวิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จักมารวมกัน

2.2 ข้อดีและข้อเสียของระบบตรวจจับผู้บุกรุก

2.2.1 ข้อดีของระบบตรวจจับผู้บุกรุก

1) การตอบสนองทันทีทันใด

จริงๆ แล้วการวิเคราะห์การบุกรุกนั้น หากเป็นผู้เชี่ยวชาญที่มีความรู้ความเข้าใจด้านเน็ตเวิร์คและโปรโตคอลเป็นอย่างดีก็จะวิเคราะห์ได้โดยอาศัยเครื่องมือเพียงเล็กน้อยเท่านั้น คือ ใช้เครื่องมือทำการจัดเก็บบันทึกข้อมูลทั้งหมดที่มีการสื่อสารกันบนเน็ตเวิร์ค แล้วนำข้อมูลที่ได้เหล่านั้นมาวิเคราะห์โดยพฤติกรรมและความสัมพันธ์ ก็จะสามารถหาสิ่งผิดปกติที่เกิดขึ้นได้ แต่การวิเคราะห์ในลักษณะดังกล่าวจะกระทำได้อีกต่อเมื่อได้เกิดเหตุการณ์ไปแล้ว เนื่องจากการวิเคราะห์จะเป็นไปในลักษณะการวิเคราะห์ข้อมูลย้อนหลัง ไม่สามารถจะกระทำได้ในทันที ซึ่งระบบตรวจจับผู้บุกรุก จะช่วยแก้ไขข้อบกพร่องในส่วนนี้ เพราะ ระบบตรวจจับผู้บุกรุก สามารถตรวจจับได้ทันทีที่มีความผิดปกติเกิดขึ้น และช่วยให้ทำการแก้ไขได้ทันทั่วถึง การทำงานพื้นฐานของ ระบบตรวจจับผู้บุกรุก จะเหมือนกับการที่ทำโดยคน เพียงแต่ระบบตรวจจับผู้บุกรุกนั้นทำงานโดยอัตโนมัติและการทำงานอยู่ตลอดเวลาไม่มีหยุด จึงสามารถตอบสนองต่อสิ่งผิดปกติได้รวดเร็วกว่า ซึ่งถ้าให้คนมานั่งตรวจจับก็ไม่สามารถทำได้ตลอดเวลา

2) การมีฐานความรู้ของการวิเคราะห์

จากที่ได้กล่าวมาข้างต้น การที่จะตรวจจับสิ่งผิดปกติและแยกแยะกิจกรรมเหล่านั้นนอกจากการสื่อสารข้อมูลตามปกติได้นั้นจะต้องอาศัยความชำนาญ และเข้าใจในรูปแบบของการสื่อสารข้อมูลและการบุกรุกเป็นอย่างดี นั่นคือทักษะที่จำเป็นของนักวิเคราะห์การบุกรุก (Intrusion Analyst) ซึ่งผู้เชี่ยวชาญในระดับที่จะทำงานเช่นนี้ได้มีไม่มากนัก ประกอบกับเทคนิคและกลวิธีในการบุกรุกหรือก่อการนั้นได้พัฒนาขึ้นทุกวัน วิธีการตรวจจับและวิเคราะห์จำเป็นต้องพัฒนาตามให้สอดคล้องกันจึงจะตรวจจับได้อย่างมีประสิทธิภาพ ซึ่งในส่วนนี้ผู้เชี่ยวชาญเองก็อาจจะทำได้ไม่ดีเท่า

ระบบตรวจจับผู้บุกรุก สามารถช่วยแบ่งเบาภาระของนักวิเคราะห์ลงได้มาก โดยหากรู้รูปแบบพฤติกรรมแน่ชัดว่าเป็นการมุ่งร้ายก็ให้จัดเก็บข้อมูลรูปแบบเหล่านั้นในระบบตรวจจับผู้บุกรุกเสีย เมื่อมีกิจกรรมดังกล่าวเกิดขึ้นในเน็ตเวิร์ก ระบบตรวจจับผู้บุกรุก ก็สามารถตรวจพบได้ทันที และเมื่อค้นพบรูปแบบใหม่ก็จัดเก็บลงในระบบตรวจจับผู้บุกรุก อีกทั้งทำให้ระบบตรวจจับผู้บุกรุกเสมือนมีฐานความรู้ในการวิเคราะห์การบุกรุกได้ดีในระดับหนึ่ง และขีดความสามารถก็จะเพิ่มขึ้นเรื่อยๆ ตามปริมาณของรูปแบบที่เก็บอยู่ในฐานความรู้นั่นเอง หากมีการบำรุงรักษาฐานความรู้ในตัวระบบตรวจจับผู้บุกรุกได้ดี และนำระบบตรวจจับผู้บุกรุกไปใช้ในจุดที่เหมาะสมแล้ว การบุกรุกที่ไม่ใช่เทคนิคใหม่ล่าสุดจริงๆ ก็แทบจะไม่สามารถเล็ดรอดสายตาระบบตรวจจับผู้บุกรุกไปได้ ถึงขั้นนี้แล้วแม้ว่าจะเป็นระบบตรวจจับผู้บุกรุกแบบธรรมดาๆ ก็มีความสามารถมากกว่าผู้บริหารระบบทั่วไปเสียอีก

สำหรับนักวิเคราะห์แล้วเมื่อมีระบบตรวจจับผู้บุกรุกจะทำให้ไม่ต้องห่วงหน้าพะวงหลัง เพราะการบุกรุกที่สามารถตรวจจับได้ง่ายๆ ก็สามารถตรวจพบได้โดยระบบตรวจจับผู้บุกรุก อย่างน้อยระบบตรวจจับผู้บุกรุกก็ช่วยกลั่นกรองข้อมูลเบื้องต้นได้ในระดับหนึ่งและแบ่งเบาภาระได้พอสมควร

3) การช่วยตรวจสอบข้อบกพร่องของระบบป้องกันอื่น ๆ

เน็ตเวิร์กของผู้ใช้อาจมีการป้องกันการบุกรุกอยู่แล้วโดยใช้ไฟร์วอลล์ (Firewall) อย่างไรก็ตามไฟร์วอลล์ไม่ใช่เครื่องมือที่จะป้องกันการบุกรุกได้โดยอัตโนมัติ จะต้องอาศัยผู้ที่บริหารระบบกำหนดกฎให้เหมาะสมกับการใช้งาน อีกประการหนึ่ง ถึงแม้จะมีการตั้งกฎที่เหมาะสมแล้วก็ตาม แต่กฎเหล่านั้นอาจไม่สามารถป้องกันการบุกรุกได้ การบริหารไฟร์วอลล์ที่ดีก็ควรจะมีการตรวจสอบย้อนหลัง (Audit) และการทดสอบการเจาะระบบ (Penetration Test) เพื่อเป็นการสอบทานระบบอีกครั้งหนึ่ง

ระบบตรวจจับผู้บุกรุก สามารถช่วยได้มาก โดยติดตั้งระบบตรวจจับผู้บุกรุก ไว้หลังไฟร์วอลล์ และทำการทดสอบเจาะระบบด้วยวิธีต่างๆ เพื่อดูว่าจะมีเทคนิคใดที่สามารถเจาะผ่านไฟร์วอลล์ได้บ้าง และหากมีแพ็คเกจใดผ่านเข้าไปได้ระบบตรวจจับผู้บุกรุก ก็จะตรวจพบทำให้ผู้บริหารระบบสามารถปรับปรุงกฎให้รัดกุมมาก

2.2.2 ข้อเสียของระบบตรวจจับผู้บุกรุก

ถึงแม้ระบบตรวจจับผู้บุกรุก จะมีประโยชน์ค่อนข้างมากในการช่วยรักษาความปลอดภัยและการเตือนภัยล่วงหน้า แต่ก็มีข้อเสียอยู่หลายประการซึ่งผู้ที่นำไปใช้จะต้องตระหนักไว้

1) การละเมิดความเป็นส่วนตัว

เนื่องจากระบบตรวจจับผู้บุกรุก มีพื้นฐานจากการนำข้อมูลทั้งหมดที่สื่อสารกันมาทำการวิเคราะห์ ซึ่งข้อมูลเหล่านั้นจะต้องครอบคลุมถึงข้อมูลทั่วไปที่มีการสื่อสารกันตามปกติ และการที่จะทราบว่ามีคามผิดปกติหรือไม่นั้นก็ต้องอ่านข้อมูลทั้งหมดด้วย ดังนั้นไม่ว่าจะมีกิจกรรมใดๆ ที่เกิดขึ้นในเน็ตเวิร์คไม่ว่าจะเป็นการท่องเว็บ การดาวน์โหลดข้อมูล การแชทคุยกัน ไอซีคิว อี-เมล และกิจกรรมอื่นๆ ที่สื่อสารข้อมูลผ่านเน็ตเวิร์ค ก็จะสามารถถูกเปิดอ่านได้จากระบบตรวจจับผู้บุกรุก นั่นหมายความว่าระบบตรวจจับผู้บุกรุก สามารถนำไปใช้ในทางที่ผิดเพื่อละเมิดสิทธิส่วนบุคคลได้ การทำงานของระบบตรวจจับผู้บุกรุก เปรียบเสมือนการที่ตำรวจต้องการตรวจสอบและดักจับผู้ไม่หวังดีที่คอยโทรศัพท์ก่อความวุ่นวายในหมู่บ้าน และเพื่อการนี้ตำรวจจึงต้องทำการดักฟังโทรศัพท์ของทุกคนที่อยู่ในหมู่บ้านนั้น ซึ่งอาจจะมีเพียงหนึ่งในพันที่เป็นผู้ร้าย แต่ตำรวจผู้ทำหน้าที่ดักฟังก็จะรู้ความลับของทุกคน บางคนก็มีการดักฟังความลับของทุกคนอาจเป็นอันตรายกว่าการโดนผู้ร้ายก่อความวุ่นวายก็เป็นได้

ดังนั้นการนำ ระบบตรวจจับผู้บุกรุก มาติดตั้งในเน็ตเวิร์คจะต้องได้รับการอนุมัติจากหน่วยงานอย่างถูกต้องแล้วเท่านั้น และผู้ทำหน้าที่ในด้านนี้จะต้องเป็นผู้ที่ได้รับความไว้วางใจและมีความรับผิดชอบสูงในอันที่จะไม่ละเมิดสิทธิส่วนบุคคลของผู้อื่น และหากเห็นข้อมูลใดๆ ก็จะต้องไม่เปิดเผยข้อมูลเหล่านั้นแก่บุคคลนั้น โดยทั่วไปแล้วการติดตั้งอุปกรณ์ที่สามารถอ่านข้อมูลของผู้อื่นบนเน็ตเวิร์คได้นั้นจะเป็นข้อห้ามอันดับต้นๆ ในนโยบายรักษาความปลอดภัยเลยทีเดียว สิ่งที่เป็นข้อสังเกต คือ การกระทำในลักษณะนี้ยากต่อการป้องกันในทางเทคนิค ดังนั้นหน่วยงานโดยทั่วไปจึงต้องกำหนดเป็นข้อห้ามในนโยบายความปลอดภัย และมีบทลงโทษสำหรับผู้ที่จะละเมิดในขั้นรุนแรง

2) การตอบโต้อัตโนมัติ

ระบบตรวจจับผู้บุกรุก ที่มีจำหน่ายอยู่ในท้องตลาดจะมีส่วนหนึ่งที่ทำให้ผู้ใช้สามารถกำหนดการดำเนินการอย่างหนึ่งอย่างใดเมื่อตรวจพบการบุกรุกเกิดขึ้น เช่น ส่งจดหมายเตือนผู้ดูแลระบบ เรียกวิทยุติดตามตัว ส่งคำสั่งไปยังไฟร์วอลล์เพื่อจำกัดการเข้าออกของข้อมูล และสิ่งที่สำคัญที่สุดซึ่งอาจจะส่งผลเสียหายใหญ่หลวงต่อเจ้าของได้ก็คือ การโจมตีกลับไปยังต้นกำเนิดของการบุกรุก (Counter attack) โดยที่ระบบตรวจจับผู้บุกรุกเองก็จะรู้จักวิธีการโจมตีแบบต่างๆ คืออยู่แล้ว จึงมิใช่เรื่องยากเย็นแต่อย่างใดที่จะทำการโจมตีผู้อื่น ผู้ผลิตจึงมักเพิ่มเติมส่วนนี้ให้แก่ระบบตรวจจับผู้บุกรุกเสมือนหนึ่งการติดอาวุธๆ ไว้ให้ต่อสู้กับแฮกเกอร์เลยทีเดียว

ผู้ดูแลระบบบางส่วนอาจรู้สึกสะใจและคิดว่าเหมาะสมแล้วกับการโจมตีกลับไปยังแฮกเกอร์เหล่านั้นไม่ให้หลบจำจะได้ไม่พยายามมาซ้ำแฉะอีก เป็นนโยบายการรักษาความปลอดภัยแบบตาต่อตาฟันต่อฟัน และเชื่อว่าหากกำหนดให้การโจมตีกลับเป็นไปอย่างอัตโนมัติแล้วน่าจะทำให้ปลอดภัยมากขึ้น ในคำคืนที่เรียบสงบใครจะไปรู้ว่าระบบตรวจจับผู้บุกรุก อาจจะกำลังต่อสู้กับแฮกเกอร์ที่พยายามแอบเข้ามาในระบบอย่างสุดกำลัง และสู้ยิบตาเพื่อรักษามิให้แฮกเกอร์บุกรุกเข้ามาในเน็ตเวิร์คได้ ในโลกแห่งความเป็นจริงแล้วการตัดสินใจว่าผู้ใดเป็นแฮกเกอร์อย่างชัดเจนมิได้ทำได้โดยง่าย และในเวลาอันรวดเร็ว การที่กำหนดให้ระบบตรวจจับผู้บุกรุก ทำการตอบโต้กลับไปในทันทีโดยมีข้อมูลเพียงผิวเผินนั้น นอกจากจะ

ไม่ช่วยให้เน็ตเวิร์คของเราปลอดภัยแล้ว ยังจะทำให้เรากลายเป็นแอสกเกอร์ ที่คอยโจมตีผู้อื่นเสียเอง ยกตัวอย่างความเสียหาย เช่น

- การวิเคราะห์ผิดพลาดเข้าใจว่ากิจกรรมที่เกิดขึ้นเป็นการบุกรุก และระบบตรวจจับผู้บุกรุก ก็ดำเนินการโจมตีกลับไปทันที กรณีนี้ผู้บริสุทธิ์ก็จะถูกโจมตีจากระบบตรวจจับผู้บุกรุก ของเรา โดยที่ไม่รู้เรื่องใดๆ
- การวิเคราะห์ถูกต้องแต่แอดเรสของต้นทางเป็นแอดเรสปลอม กรณีนี้หาก ระบบตรวจจับผู้บุกรุก ไม่มีกลไกในการตรวจสอบแอดเรสที่มีประสิทธิภาพ อาจไม่สามารถแยกแยะได้ว่าต้นทางของการโจมตีแท้จริงนั้นเป็นที่ไหน และเมื่อทำการโจมตีกลับไปก็อาจจะมีไช่ตัวการที่แท้จริง และเหตุการณ์จะเลวร้ายยิ่งขึ้นหากแอดเรสที่ปลอมมานั้นเป็นของหน่วยงานทางความมั่นคง หรือหน่วยงานทางทหาร และเมื่อนั้นผู้ดูแลระบบอาจจะตระหนักได้ว่า ระบบตรวจจับผู้บุกรุก ตัวเดียวอาจจะทำให้เขาต้องเข้าไปนอนในคุกหลายคืน เทคนิคการปลอมแอดเรสลักษณะนี้อาจเป็นการยืมมือ ระบบตรวจจับผู้บุกรุกของเราไปโจมตีผู้อื่นอีกทอดหนึ่งได้เป็นอย่างดี
- การวิเคราะห์แอดเรสที่ถูกต้อง และการโจมตีกลับไปก็ตรงไปยังแอสกเกอร์อย่างถูกต้องตามที่ ต้องการ แต่ผลที่ได้ก็เพียงอาจจะทำให้แอสกเกอร์หยุดความพยายามไปชั่วขณะเท่านั้น อีกไม่นานก็จะหาวิธีกลับมาใหม่ และไม่เกิดผลใดๆ เลยนอกจากจะเป็นการช่วยผู้ที่มีความรุนแรงมากขึ้น เท่านั้น

สิ่งสำคัญที่ผู้ทำหน้าที่ด้านความปลอดภัยและผู้บริหารระบบควรจะต้องตระหนักไว้ให้จงหนักคือ ท่านไม่มีสิทธิพิเศษที่จะไปตอบโต้ผู้บุกรุกโดยการโจมตีกลับไม่ว่าในกรณีใด สิ่งที่ท่านจะทำให้ได้ดีที่สุด คือ ทำระบบให้แข็งแรงมั่นคงและปลอดภัยที่สุดเท่านั้น นั่นคือปิดประตูบ้านให้แน่น ตรวจสอบอย่างรัดกุม และใช้งานเท่าที่จำเป็น ส่วนผู้ที่กระทำผิดเหล่านั้นควรจะปล่อยให้เป็นไปตามกฎหมายและกระบวนการยุติธรรมจะดีที่สุด เพราะการตอบโต้การกระทำที่ผิดกฎหมายด้วยวิธีที่ผิดกฎหมายจะทำให้เรากลายเป็นจำเลยไปด้วยในที่สุด

3) การเตือนภัยที่ผิดพลาด

ข้อนี้อาจไม่ใช่ข้อเสียที่สำคัญของการใช้ระบบตรวจจับผู้บุกรุก หากผู้ใช้มีความรู้ในการใช้งานที่ดีพอและเข้าใจหลักการวิเคราะห์การบุกรุกของระบบตรวจจับผู้บุกรุกได้ดี อย่างที่ได้กล่าวแล้วข้างต้น ก็คือ อาจจะมีกิจกรรมปกติหลายอย่างที่มีลักษณะใกล้เคียงหรือบางครั้งเหมือนกับการพยายามบุกรุก ซึ่งแน่นอนว่าหากระบบตรวจจับผู้บุกรุก ได้ถูกกำหนดให้ตรวจจับกิจกรรมประเภทดังกล่าวแล้วก็จะมีการเตือนในทันทีที่ตรวจพบและเป็นหน้าที่ของนักวิเคราะห์ที่จะทำการสืบค้นข้อมูลด้านอื่นๆ มาประกอบการวินิจฉัยอีกครั้งหนึ่งว่าพฤติกรรมดังกล่าวที่ตรวจพบนั้นเป็นการบุกรุกหรือไม่อย่างไร ระบบตรวจจับผู้บุกรุกที่ถูกกำหนดให้มีความไวเป็นพิเศษมักจะสามารถตรวจจับพฤติกรรมที่กำลังนั้นได้มากเป็นพิเศษ ตัวอย่างเช่น ระบบตรวจจับผู้บุกรุก ได้ถูกกำหนดไว้ว่า เมื่อได้รับ Ping Packet จากแอดเรสเดิมติดต่อกัน 10 แพ็กเกจภายใน 30 วินาที ให้เตือนว่าเป็นการพยายามโจมตีโดยเทคนิค Ping Flood เป็นต้น

หากเน็ตเวิร์กดังกล่าวเป็นเน็ตเวิร์กที่ใช้งานโดยวิศวกรระบบ และมีการทดสอบการ Ping บ่อยๆ ก็อาจจะทำให้ระบบตรวจจับผู้บุกรุกเตือนอยู่แทบตลอดเวลาโดยไม่ได้มีการบุกรุกที่แท้จริง

การเตือนโดยมิได้มีการบุกรุกจริงนั้น อาจจะดูเหมือนว่าไม่ส่งผลเสียหายประการใดและน่าจะเกิดประโยชน์เสียด้วยซ้ำ เพราะจะทำให้ผู้ดูแลระบบมีความตื่นตัวตลอดเวลา แต่ในความเป็นจริงแล้วธรรมชาติของมนุษย์มีแนวโน้มจะละเลยต่อสิ่งเหล่านี้ หากมีการเตือนแล้วไม่มีการบุกรุกจริงบ่อยครั้งเข้าความน่าเชื่อถือของ ระบบตรวจจับผู้บุกรุก ก็จะลดลงตามลำดับ และเมื่อมีความพยายามบุกรุกจริงก็จะไม่ได้ให้ความสนใจเท่าที่ควรและไม่ได้หาทางป้องกันอย่างเหมาะสม นั่นคือ ระบบตรวจจับผู้บุกรุก จะกลายเป็นเด็กเลี้ยงแกะที่เวลาหมาป่าเข้ามาจริงก็ไม่มีผู้ใดรับฟัง ดูเผินๆ อาจจะเหมือนว่ายังดีกว่าการไม่มีระบบตรวจจับผู้บุกรุก เสียเลยแต่การมีระบบตรวจจับผู้บุกรุกอยู่ในระบบโดยไม่ได้นำมาปรับแต่งอย่างเหมาะสม และเชื่อมั่นว่าระบบตรวจจับผู้บุกรุก สามารถจะคอยระแวดระวังและเก็บหลักฐานต่างๆ ไว้ให้นั้นจะทำให้ผู้บริหารระบบนิ่งนอนใจและลดความเคร่งครัดในการปฏิบัติงานลง อาจจะถึงขั้นหย่อนยานกว่าการป้องกันในระดับปกติที่ไม่มี ระบบตรวจจับผู้บุกรุกได้ นอกจากนี้การปล่อยให้ ระบบตรวจจับผู้บุกรุก มีการเตือนอย่างไม่เหมาะสมทำให้เกิดข้อมูลในลักษณะที่เป็นการบุกรุกจริงและการเตือนผิดพลาดผสมกันอยู่ อาจทำให้การเตือนที่เป็นของจริงถูกกลบไปและยากต่อการสังเกต อย่าลืมว่าแฮ็กเกอร์ที่มีความสามารถจะทิ้งร่องรอยของการบุกรุกไว้เพียงเล็กน้อยอาจจะมีเพียง 2-3 ร่องรอยเท่านั้นที่ ระบบตรวจจับผู้บุกรุก สามารถตรวจพบได้หากร่องรอยเหล่านี้ถูกนำไปผสมปนเปกับการตรวจจับอื่นๆ อีกนับพัน ย่อมมีโอกาสสูงที่จะถูกมองเลยไปโดยไม่มีผู้ใดให้ความสนใจ

2.3 ชนิดของการบุกรุก

2.3.1 การบุกรุกจากภายนอก (Outside Intruders)

การบุกรุกจากภายนอกคือ การบุกรุกจากผู้ที่ไม่ได้รับอนุญาตในการเข้าระบบผู้ที่เข้ามาโจมตีจะทำการขโมย หรือทำลาย Password ทำให้ระบบเกิดข้อผิดพลาด หรือเปลี่ยนแปลงรูปแบบ เพื่อเข้าสู่ระบบ

2.3.2 การบุกรุกจากภายใน (Inside Intruders)

การบุกรุกจากภายใน คือ การบุกรุกจากผู้ที่ใช้ที่ได้รับการอนุญาตให้เข้า แต่ทำการเข้าถึงระบบนอกเหนือจากขอบเขตที่ได้รับ เพื่อที่จะใช้งาน หรือ ทำความเสียหายแก่ระบบ การบุกรุกประเภทนี้ได้สร้างความเสียหายแก่ระบบมากกว่าการบุกรุกจากภายนอก จากรายงานของ FBI ผลออกมาการบุกรุกจากภายในมีปริมาณสูงกว่าการบุกรุกจากภายนอกถึง 80% โดยแบ่งเป็น 3 ประเภท ได้แก่

- ผู้ใช้ตัวปลอมโดยใช้สิทธิในการเข้าระบบของผู้ใช้คนอื่นที่มีสิทธิถูกต้อง
- ผู้ใช้ที่หลบหนีเข้ามาในระบบ คือผู้ที่เข้ามาในระบบได้สำเร็จโดยหนีพ้นจากการตรวจจับ
- ผู้ใช้ที่มีสิทธิพิเศษ คือ ผู้ใช้ที่มีสิทธิพิเศษในการเข้าระบบ

2.4 พฤติกรรมโดยทั่วไปของผู้บุกรุก

โดยประกอบด้วยขั้นตอนสำคัญ 3 ขั้นตอนจำเป็นและเป็นพื้นฐานทั่วไปของการบุกรุก

2.4.1 การแกะรอย (Footprinting)

เป็นการรวบรวมข้อมูลของเครื่องเป้าหมายที่ต้องการให้ได้มากที่สุด โดยเฉพาะช่องโหว่ที่มีอยู่บนเน็ตเวิร์ค ทำให้ทราบโปรไฟล์ (Profile) ของเครื่องเป้าหมายที่เชื่อมต่ออยู่กับอินเทอร์เน็ต (Internet) ทั้งในส่วนของเน็ตเวิร์คภายในหรืออินทราเน็ต (Intranet) และเอ็กซ์ทราเน็ต (Extranet) รวมทั้งการให้บริการการเชื่อมต่อจากระยะไกล (remote access) ประกอบด้วย 3 ขั้นตอนย่อย ดังนี้

- 1) กำหนดขอบเขตของการแกะรอย เป็นการพิจารณาว่าต้องการแกะรอยเน็ตเวิร์คทั้งองค์กรหรือสนใจเฉพาะบางส่วนโดยค้นหาข้อมูลจากแหล่งข้อมูลที่เปิดเผยได้ (Open Source Search) ทำให้ทราบข้อมูลบางอย่างที่น่าสนใจได้ เช่น นโยบายด้านการรักษาความปลอดภัยซึ่งบ่งบอกให้ทราบถึงกลไกการรักษาความปลอดภัยที่ใช้งานอยู่ปัจจุบัน ชื่อผู้ติดต่อและอี-เมลแอดเดรส หรือตำแหน่งที่ตั้ง
- 2) การรวบรวมรายละเอียดต่างๆ ของเน็ตเวิร์คเป้าหมาย โดยหาชื่อโดเมนและเน็ตเวิร์คที่เกี่ยวข้องกับเครื่องเป้าหมาย แล้วเรียกใช้โปรแกรม เช่น whois (เป็นโปรแกรมที่ใช้หาข้อมูลว่ามีใครใช้งานอยู่ในระบบบ้าง) ดูโดเมนเนมของระบบ และค้นหาคำกำหนดของเครื่องที่ทำงานอยู่ในเน็ตเวิร์ค เช่น ชื่อเครื่องรุ่นของระบบปฏิบัติการ ชื่อผู้ใช้ทั้งหมดในระบบ
- 3) การสำรวจเน็ตเวิร์ค โดยพยายามสำรวจเส้นทางที่แพ็กเก็ตไอพี เริ่มส่งจากเครื่องต้นทางไปถึงปลายทาง

2.4.2 การสแกนเพื่อตรวจสอบ

เปรียบเทียบการเคาะกำแพงเพื่อสำรวจหาประตูบ้านและหน้าต่าง (ช่องโหว่) โดยการแกะรอยจะทำให้ได้ไอพีแอดเดรส และข้อมูลเกี่ยวกับเน็ตเวิร์คของเครื่องเป้าหมายผ่านการทางสอบถามจากฐานข้อมูล whois ส่วนต่อมาก็คือ ทำการตรวจสอบว่าเครื่องคอมพิวเตอร์ปลายทางใดบ้างที่เปิดอยู่และสามารถเข้าถึงได้โดยตรงผ่านทางอินเทอร์เน็ตและถ้าเป็นไปได้ควรทราบด้วยว่า มีหมายเลขพอร์ตใดเปิดอยู่บ้าง โดยการใช้เครื่องมือและเทคนิคต่างๆ เช่น ping sweeps , port scans และ automated discovery tools

2.4.3 การค้นหาและรวบรวมรายละเอียด (Enumeration)

เป็นการค้นหาบัญชีผู้ใช้หรือค้นหาทรัพยากรที่แชร์ไว้ ซึ่งข้อแตกต่างสำคัญระหว่างเทคนิคการรวบรวมข้อมูลและเบาะแสกับการค้นหาและรวบรวมรายละเอียดต่างๆ คือ ระดับหรือความร้ายแรงของการบุกรุก หมายความว่า มีการเปิดคอนเนกชันไปยังเครื่องปลายทางโดยตรงและมีการส่งคำถามถามไปด้วย เมื่อแฮกเกอร์ทราบชื่อแอดเดรสของผู้ใช้ที่ถูกต้องหรือทราบชื่อแชร์โฟลเดอร์ ผู้บุกรุกจะพยายามทำการคาดเดารหัสผ่านหรือค้นหาจุดบกพร่องของสิทธิ์ที่เซตไว้ที่แชร์โฟลเดอร์นั้นๆ เมื่อผู้บุกรุกสามารถเข้าไปเป็นผู้ใช้ทั่วไปแล้วก็สามารถหาช่องทางขยายสิทธิ์ให้เป็นผู้ดูแลระบบ

ประเภทของข้อมูลที่แฮกเกอร์ ต้องการรวบรวม สามารถแบ่งออกเป็น 3 กลุ่มใหญ่ คือ

- รายชื่อทรัพยากรในเน็ตเวิร์ค เช่น ชื่อเซิร์ฟเวอร์ เป็นต้น
- รายชื่อแอดเดรสของผู้ใช้และรายชื่อกลุ่ม
- รายชื่อแอปพลิเคชัน

2.5 แนวทางการปฏิบัติเมื่อมีการบุกรุกระบบ

- จัดตั้งกลุ่มที่รับผิดชอบในการจัดการได้ทันทีที่ทราบว่าถูกบุกรุก
- กำหนดแนวทางในการรับมือ เช่น ควรให้ความสำคัญกับการจัดการให้เน็ตเวิร์คทำงานได้ปกติในสภาพเดิมเร็วที่สุด หรือให้ความสำคัญในการหาตัว ผู้บุกรุกผู้ดูแลระบบสามารถถอดสายเน็ตเวิร์คโดยทันทีหรือไม่หากพบว่าผู้บุกรุกกำลังทำความเสียหายกับระบบอยู่เมื่อพบผู้บุกรุกแล้วจะคอยดูพฤติกรรมต่อไปหรือจัดการทันที ให้ลองคิดปัญหาที่เกิดขึ้นแล้วหาแนวทางการดำเนินการก่อนที่จะเกิดขึ้นจริง เพราะเมื่อเกิดเหตุการณ์ขึ้นแล้วจะไม่มีเวลาคิด
- ให้กำหนดแนวทางในการแจ้งปัญหา เช่น หากเกิดปัญหาแล้วจะแจ้งผู้บังคับบัญชาในลำดับสูงขึ้นไปก่อน หรือแจ้งหน่วยงานที่เกี่ยวข้องเลย ต้องแจ้งเหตุการณ์การบุกรุกที่เกิดขึ้นกับหน่วยงานที่คอยให้คำปรึกษาและช่วยเหลือใด (ในอเมริกามีหลายหน่วยงาน เช่น FIRST หรือ CERT) ต้องแจ้งตำรวจหรือไม่ จะแจ้งเหตุการณ์นี้กับหุ้นส่วนทางธุรกิจหรือไม่ จะปิดข่าวนี้นับหนังสือพิมพ์หรือไม่
- ให้จัดระบบและขั้นตอนในการดำเนินงานในการเก็บล็อก วิเคราะห์ และเฝ้าติดตามข้อมูลทันที ประเด็นสำคัญในการหาร่องรอยของผู้บุกรุก คือ ต้องมีการเก็บล็อกอย่างเพียงพอสำหรับการวิเคราะห์
- ให้คำแนะนำกับผู้ใช้ทุกคนให้ทราบเกี่ยวกับการป้องกันการบุกรุก